



Validating Vanta's multi-tenant isolation architecture

Vanta helps thousands of companies earn and prove trust with its Agentic Trust Platform. Their platform handles sensitive customer data across isolated tenant environments. Cross-tenant isolation is the foundation of their customers' trust, making proper access controls and authorization mechanisms a fundamental concern.

Vanta engaged Trail of Bits to validate whether their authorization architecture would hold up to adversarial scrutiny and to identify design-level improvements for long-term resilience.

Two consultants spent six weeks reviewing Vanta's cross-tenant isolation and data store access patterns across their entire stack, including GraphQL endpoints, async job handlers, and internal services. The assessment validated Vanta's architectural approach while identifying improvements to mitigate edge cases.

Before the Engagement

External audits deliver the most value when you've already invested in internal security practices. Vanta came to the engagement with strong foundations already in place.

■ Static analysis in CI/CD

Vanta runs Semgrep in their development pipeline, catching common vulnerability patterns before code reaches production. Static analysis as a guardrail, not just a scanner.

■ Internal Risk Documentation

Before the engagement began, Vanta's security team produced documentation analyzing authorization risks across their components. This kind of proactive threat modeling is rare. Most organizations wait for external auditors to identify risk areas. However, Vanta mapped them first, which improved our auditing efficiency.

Audit Scope

From November through December 2025, we reviewed Vanta's cross-tenant data access and general application security, drawing on disciplines that many security firms split across separate engagements.

01. Coverage

API Layer

GraphQL REST

Data Stores

MongoDB MySQL Redis Snowflake

Queues & Messaging

BullMQ SQS Kafka

Auth & Identity

SAML SSO Flows

Infrastructure

Internal Services IaC Configs

02. Methodology

■ Dynamic Testing

Burp Suite — live endpoint probing

■ Static Analysis

Semgrep + Trail of Bits internal ruleset, extending Vanta's existing CI/CD checks

■ Additional Coverage

CodeQL for deeper code-path analysis

■ Manual Review

Architectural pattern analysis across the full stack

03. Expertise

App Security

Auth & Identity

Cloud & IaC security

Multi-tenant auth

Backend & data layer

What We Found

Insufficient authorization controls dominate vulnerability rankings for a reason. They're OWASP's #1 web application risk of 2025 and #1 API risk of 2023. Every organization implements authorization controls differently, which makes automated bug detection challenging.

Vanta's architecture addresses this through centralized authorization middleware. A `DomainScopedMySQLOrm` filters every MySQL query by `domainId`, `createSafeSchema` protects GraphQL operations by default, and `graphql-shield` gates sensitive calls. Cross-tenant work opts in through named exceptions like `allowMultiDomains`, not ad-hoc checks scattered across endpoints. Our takeaway: this approach largely works. Isolation at the data access layer means developers don't reason about `domainId` on every call, and the exceptions stay searchable in code review.

The challenge is ensuring every code path follows this approach. When nearly every database access is protected, findings live in the "nearly" part.

Severity	Count
HIGH	1
MEDIUM	5
LOW	14
INFORMATIONAL	6
UNDETERMINED	1

Among the 27 issues we identified, the single high-severity issue related to authentication: we found that SAML authentication endpoints are vulnerable to replay attacks, allowing an attacker to take over a victim's account. The remaining findings, including five medium-severity issues, mainly related to access controls and cryptography. We found places where tenant validation was inconsistent, where API patterns could be tightened, and edge cases where code bypassed standard patterns or exposed footguns in API design.

Architectural Guidance

An audit's output shouldn't be a list of bugs. It should provide design-level guidance based on current findings to prevent future bugs. For this review, we provided three architectural recommendations to Vanta.

■ Design APIs that are hard to misuse

Functions that retrieve records without requiring tenant context create footguns. Make the secure path the default. Reserve unsafe patterns for documented, auditable exceptions.

■ Encode security deficiencies in tooling

Vanta already uses Sengrep. Extending the ruleset to detect authorization gaps turns one-time findings into permanent guardrails. When the secure pattern is well-defined, enforce it automatically.

■ Treat identifiers as an attack surface

Predictable user-facing IDs give attackers enumeration leverage. Cryptographically random identifiers provide defense in depth: even if an authorization check fails somewhere, enumeration shouldn't be easy.



"We engaged Trail of Bits because of their reputation in the security community and the thoroughness of their assessments. They asked the right questions from the start, engaging our internal SMEs and ensuring that they fully understood our application architecture and access primitives. We came away with valuable findings that we could immediately address, as well as guidance that will help us build upon a solid security foundation as we scale."

Nathan Hunstad
DIRECTOR OF SECURITY, VANTA

What's next

Security isn't a one-and-done effort.

Vanta is evaluating row-level security as the next evolution of their tenant isolation, moving authorization enforcement from application code into the database layer itself.

About Trail of Bits

Trail of Bits combines deep technical expertise with real-world attacker methodology to reduce risk in critical systems. Our application security practice reviews complex multi-tenant architectures, authentication systems, and authorization models for organizations handling sensitive data.

CONTACT: WWW.TRAILOFBITS.COM

About Vanta

Vanta is the leading agentic trust platform that helps businesses earn and prove trust. Over 15,000 companies like Atlassian, Duolingo, Golden State Warriors, Icelandair, Ramp, and Synthesia rely on Vanta to earn and prove trust continuously. Founded in 2018, Vanta serves customers in 58 countries with offices in Dublin, New York, San Francisco, Sydney, and London.

FOR MORE INFORMATION, VISIT WWW.VANTA.COM